

Manual 07 - Segurança de IA e Controles do Ciclo de Vida

CANDIDATO CONTROLADO PARA QA DE PUBLICACAO

Revisão da fonte controlada: f4b19cb81daea6053de41fb3454da4170cf6f397 | Idioma: pt-BR | limites de autorização e parada/reversão mantidos.

Limite de segurança e asseguração: Este manual educacional não demonstra que um sistema de IA seja seguro, conforme, certificado ou livre de vulnerabilidades exploráveis. Decisões sobre autorização, privilégio mínimo, parada/reversão, resposta a incidentes, risco de fornecedores e evidências exigem julgamento humano responsável.

Caminhos de implementação e segurança

Manual 07 — Caminhos de Implementação de Segurança e Ciclo de Vida de IA

Tradução de trabalho sujeita à revisão semântica humana. Este conteúdo preserva o limite de segurança do mestre controlado: reduzir risco não equivale a garantir segurança.

Essencial

Use para casos de uso de IA delimitados e ambientes menores. Controles mínimos:

- inventário, responsável, finalidade e proveniência de dados/modelos/componentes;
- modelo de ameaças e tratamento de riscos aprovado;
- identidades de privilégio mínimo e permissões explícitas de ferramentas;
- proteção de segredos e logging;
- desenvolvimento seguro e revisão de mudanças;
- avaliação pré-implantação e testes de segurança;
- monitoramento, escalonamento de incidentes e procedimentos de rollback/parada;
- rastreamento de fornecedores/componentes e evidências de decomissionamento.

Estruturado

Use para múltiplos sistemas de IA, serviços cloud, RAG, modelos/APIs externos, dados regulados ou impacto material de negócio. Acrescente:

- revisão de limites de confiança em nível de arquitetura;
- linhagem de dados/modelos/fornecedores;
- testes de injeção de prompts e limites de recuperação;
- testes de autorização de agentes/ferramentas;
- cenários de avaliação adversarial/red team;
- telemetria de segurança e detecção de anomalias;
- pontos de controle de liberação documentados e governança de exceções;
- reavaliação recorrente após mudanças de modelo/dados/ferramentas.

Aprimorado

Use para implantações de alto impacto, autônomas/agênticas, relevantes à segurança operacional, de escala empresarial ou altamente reguladas. Acrescente:

- desafio técnico independente e testes especializados;
- separação rigorosa de privilégios e aprovação de ações de alto risco;
- sandboxing/contenção e controles de egress;
- avaliação contínua e simulação de ataques;
- verificação de integridade de fornecedores/componentes;
- exercícios de resiliência, failover, parada/kill e rollback;

- aceitação executiva de riscos e governança de incidentes materiais;
- desativação formal, retenção de evidências e lições pós-incidente.

Rota de segurança do ciclo de vida

Gráfico de memória do Manual 07 1

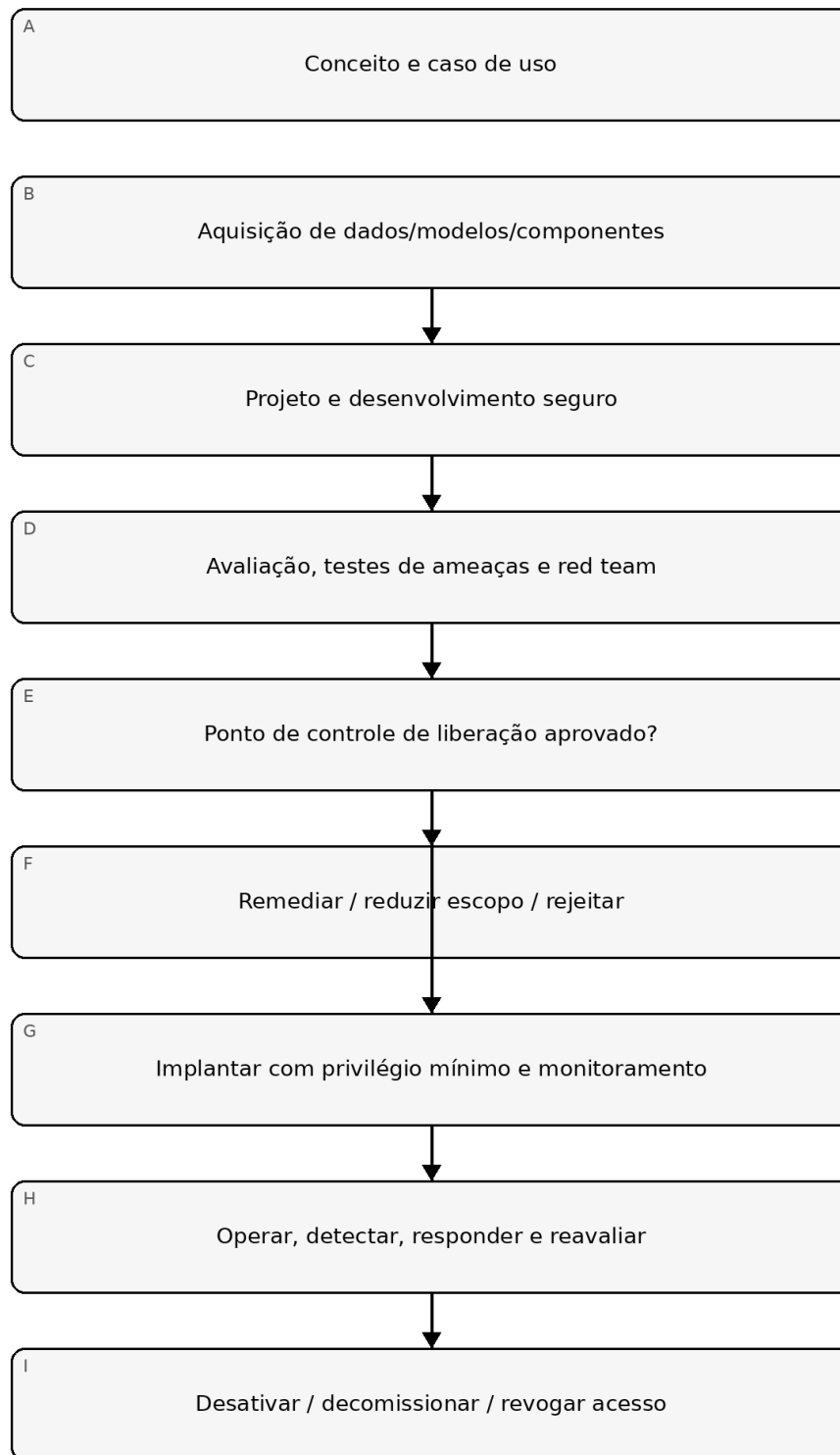


Figura 1. Gráfico de memória de implementação

Explicação acessível: A segurança começa antes do desenvolvimento e continua durante aquisição, projeto, testes, liberação, operação, resposta a incidentes e desativação. Pontos de controle de liberação reprovados devolvem o trabalho para remediação em vez de permitir implantação sem controle.

Cadeia de confiança e autorização

Gráfico de memória do Manual 07 2

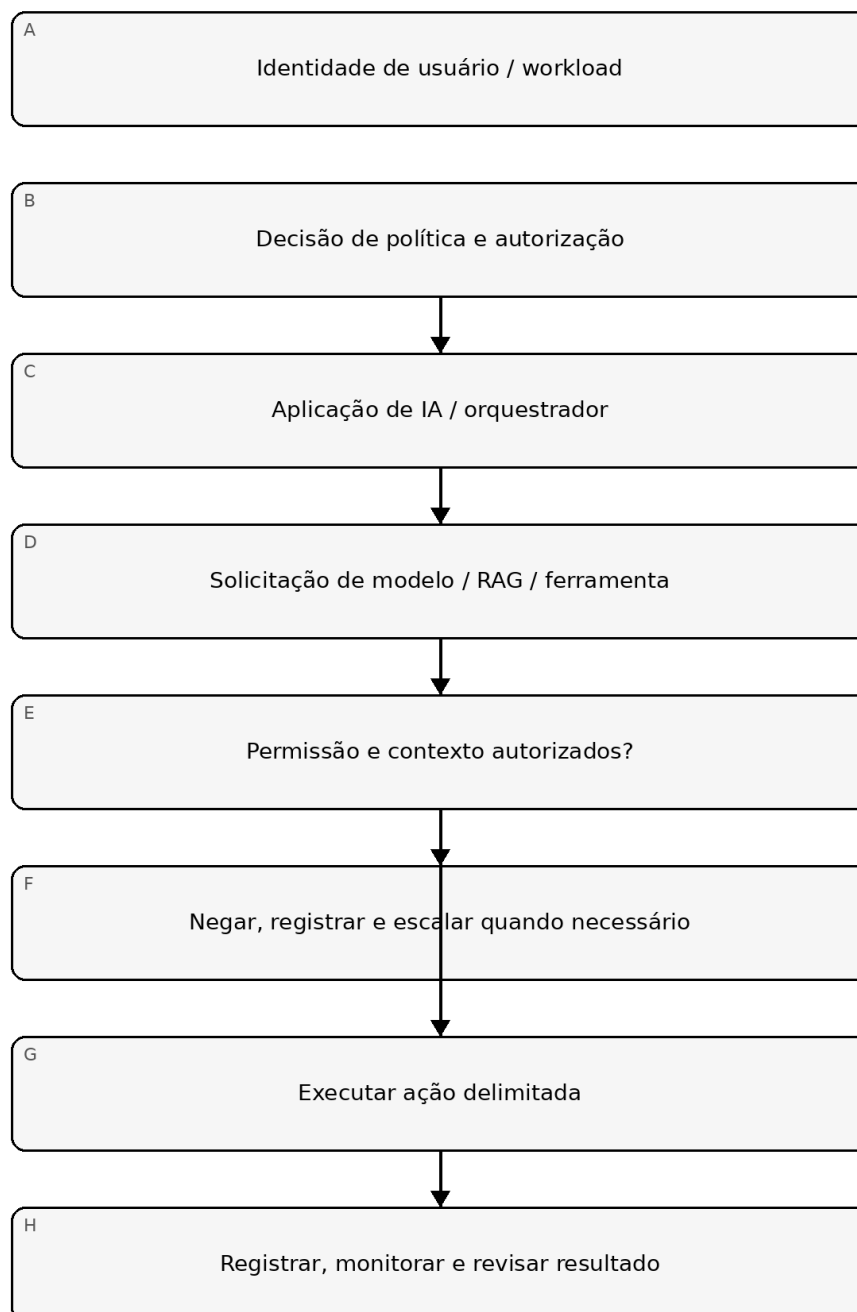


Figura 2. Gráfico de memória de implementação

Explicação acessível: Toda ação de alto valor deve passar por verificações explícitas de identidade, política, autorização e contexto. Ações negadas falham de forma fechada; ações permitidas permanecem delimitadas e observáveis.

Cadeia de evidências e recuperação

Gráfico de memória do Manual 07 3

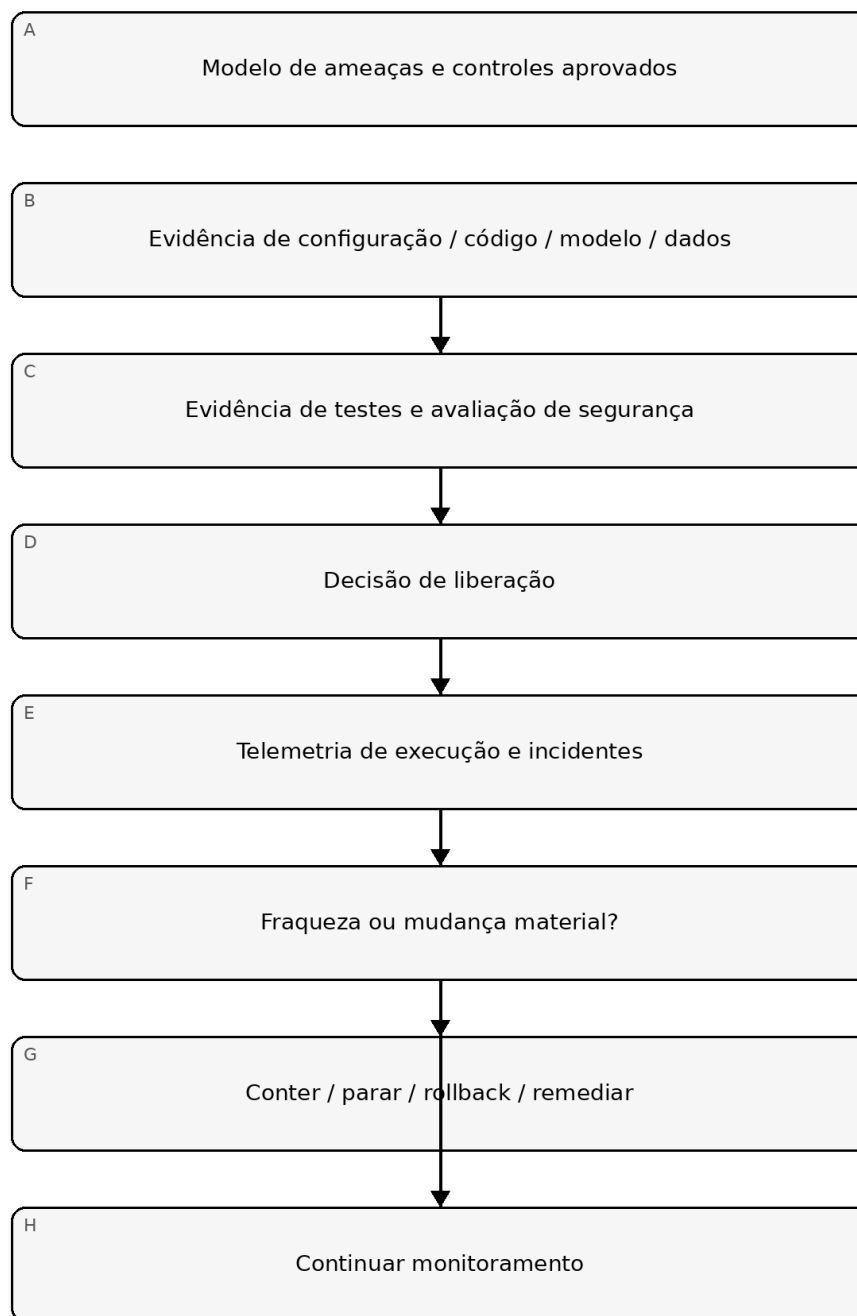


Figura 3. Gráfico de memória de implementação

Explicação acessível: Decisões de segurança são rastreáveis desde modelos de ameaças até evidências de implementação, testes, aprovação de liberação, telemetria de execução e recuperação. Fraquezas ou mudanças materiais acionam contenção e evidências renovadas, não aprovação obsoleta.

Famílias de controles obrigatórias

1. Governança, propriedade, aprovação de casos de uso, apetite de risco e autoridade de mudança.
2. Inventário de ativos, dados, modelos, prompts, bancos vetoriais, ferramentas, agentes, infraestrutura e fornecedores.
3. Modelagem de ameaças e análise de casos de uso indevido/abuso.
4. SDLC seguro e integridade de dependências/componentes.
5. Proveniência, integridade, privacidade, classificação e retenção de dados.
6. Proveniência e controle de versão de modelos/componentes.
7. Identidade, autenticação, autorização, privilégio mínimo e aprovação de ações privilegiadas.
8. Injeção direta/indireta de prompts, envenenamento de RAG, uso indevido de ferramentas e testes de controle de agentes.
9. Segredos, chaves, tokens, credenciais e confiança serviço-a-serviço.
10. Avaliação, testes de segurança, red teaming, guardrails e critérios de liberação.
11. Monitoramento, logging, detecção, resposta a incidentes, contenção, rollback e mecanismos de parada.
12. Risco de fornecedores/serviços, requisitos contratuais/de evidência e monitoramento de mudanças de dependências.
13. Desativação, decomissionamento, revogação de acesso, disposição de dados e retenção de evidências.

Limite de segurança

Defesa em profundidade e testes reduzem risco; não o eliminam. O manual deve distinguir evidência confirmada, premissas, áreas não testadas, risco residual e limitações conhecidas.

Manual controlado de 32 capítulos

Capítulo 01 — Objetivo de segurança e limite do ciclo de vida

A segurança de IA deve abranger todo o ciclo de vida do sistema, e não apenas o endpoint do modelo. O limite controlado inclui definição do caso de uso, aquisição de dados e modelos, projeto, desenvolvimento, avaliação, implantação, operação, monitoramento, resposta a incidentes, mudanças e desativação.

Cada sistema deve ter um objetivo de segurança documentado ligado aos seus dados, ações, usuários, autonomia, conectividade externa e consequências de falha.

Capítulo 02 — Inventário de ativos de IA

O inventário deve identificar modelos, conjuntos de dados, prompts, fontes de recuperação, bancos vetoriais, ferramentas, agentes, APIs, contas de serviço, segredos, guardrails, componentes de monitoramento, ambientes de hospedagem, fornecedores e sistemas críticos a jusante.

Os registros de inventário devem incluir responsável, versão, localização, classificação de dados, limite de autenticação, fornecedor, exposição, autoridade de mudança e status de desativação. Componentes desconhecidos criam superfície de ataque não gerenciada.

Capítulo 03 — Modelagem de ameaças

A modelagem de ameaças deve identificar ativos, limites de confiança, atores, pontos de entrada, privilégios, dependências e caminhos plausíveis de abuso. Ameaças específicas de IA devem ser avaliadas junto com ameaças convencionais de aplicação, nuvem, identidade, dados e cadeia de suprimentos.

Os cenários devem incluir usuários maliciosos, conteúdo de recuperação comprometido, agentes com privilégios excessivos, segredos expostos, APIs inseguras, execução insegura de ferramentas, dados envenenados, divulgação de modelo ou prompt, comprometimento de fornecedor e comportamento autônomo não intencional quando relevante.

Capítulo 04 — Desenvolvimento seguro e controle de mudanças

Componentes de IA devem ser desenvolvidos e alterados por meio de repositórios controlados, revisão, testes, gestão de dependências, controle de acesso e processos de liberação. Mudanças em prompts, políticas, recuperação, ferramentas e guardrails podem ser relevantes para segurança e não devem contornar controles de mudança apenas por não serem código tradicional.

Mudanças materiais exigem reavaliação das evidências de segurança anteriores e podem reabrir a aprovação de liberação.

Capítulo 05 — Proveniência de dados e modelos

As equipes de segurança devem conseguir identificar a origem de modelos, conjuntos de dados, pesos, adaptadores, pacotes, prompts e componentes externos, além de quem aprovou seu uso.

Os registros de proveniência devem incluir origem, versão, evidência de integridade quando disponível, limites de licença ou uso, fornecedor, aprovação, histórico de transformação e limitações conhecidas. A proveniência apoia decisões de confiança, mas não prova que um componente seja seguro.

Capítulo 06 — Identidade, privilégio mínimo e autorização de ferramentas

Sistemas de IA que invoquem ferramentas ou ações externas devem usar identidades explícitas e permissões de privilégio mínimo. O modelo não deve receber credenciais amplas apenas porque a aplicação precisa acessar múltiplas funções.

Sempre que possível, a autorização deve ser aplicada fora do modelo. Ações de alto impacto devem usar verificações de política, credenciais com escopo restrito, limites de transação, aprovação humana ou outros controles determinísticos adequados ao risco.

Capítulo 07 — Injeção de prompts e conteúdo não confiável

A injeção direta e indireta de prompts deve ser tratada como ameaça de segurança quando entradas não confiáveis puderem influenciar comportamento privilegiado, expor informações sensíveis, alterar instruções do sistema ou causar uso inseguro de ferramentas.

Os controles podem incluir isolamento de conteúdo, limites de permissão, filtragem de recuperação, validação de saída, listas permitidas de ferramentas, separação de contexto, privilégios reduzidos, etapas de confirmação e monitoramento. Nenhum prompt ou classificador isolado deve ser tratado como defesa completa.

Capítulo 08 — Gate de liberação de segurança fail-closed

A liberação deve falhar de forma fechada quando faltar evidência crítica de segurança, achados materiais permanecerem sem tratamento aprovado, testes adversariais obrigatórios não tiverem sido concluídos, rollback ou contenção forem necessários mas não testados, ou revisão humana obrigatória estiver incompleta.

Um workflow automatizado verde apoia a decisão de liberação, mas não garante que o sistema seja seguro. A aprovação final permanece um gate controlado por humanos, e mudanças materiais após a revisão reabrem a análise de segurança afetada.

Capítulo 09 — Segurança de recuperação e fontes de conhecimento

Fontes de recuperação devem ser tratadas como entradas influenciadas externamente. Os controles devem abordar admissão de fontes, autoridade de escrita, validação de conteúdo, controle de acesso, separação entre tenants, conteúdo desatualizado, exposição de dados sensíveis e remoção.

Bancos vetoriais e índices devem herdar controles apropriados de classificação de dados, acesso, retenção, logging e backup.

Capítulo 10 — Tratamento de segredos e dados sensíveis

Segredos não devem ser incorporados em prompts, código-fonte, notebooks ou contexto do modelo quando existirem alternativas mais seguras. Credenciais de serviço devem ter escopo restrito, ser rotacionadas, monitoradas e armazenadas usando mecanismos aprovados de gestão de segredos.

Logs, traces, avaliações e artefatos de suporte também devem ser revisados para exposição não intencional de dados sensíveis.

Capítulo 11 — Cadeia de suprimentos de modelos e componentes

A revisão de segurança deve incluir origem do modelo, pacotes, contêineres, adaptadores, conjuntos de dados, APIs, plugins, serviços de segurança e dependências de hospedagem. Os componentes devem ser versionados e rastreáveis para que as equipes de segurança possam avaliar o impacto de mudanças em fornecedor ou componente.

Mudanças materiais de fornecedores devem acionar reavaliação em vez de serem herdadas silenciosamente.

Capítulo 12 — Avaliação e validação de segurança

A avaliação de segurança deve usar objetivos e resultados esperados baseados em risco. A validação deve cobrir se controles de acesso, limites de dados, permissões de ferramentas, controles de recuperação, tratamento de saídas, comportamento de dependências e restrições operacionais funcionam conforme esperado em condições representativas e de limite.

A evidência de teste deve registrar configuração, escopo, resultado, limitação e remediação.

Capítulo 13 — Desafio independente

O desafio independente deve testar se premissas e limites de controle continuam válidos fora das condições normais de operação. A revisão deve ser autorizada, delimitada e orientada por evidências.

Atividade de desafio sem responsável pela remediação e sem validação de acompanhamento não deve ser apresentada como assecuração.

Capítulo 14 — Guardrails e controles determinísticos

Guardrails podem reduzir risco, mas devem ser combinados com controles de segurança determinísticos quando as consequências forem significativas. Autorização, validação de entrada, validação de saída, listas permitidas, limites de transação, controles de rede e aprovação humana podem fornecer aplicação mais forte que o comportamento do modelo isoladamente.

Capítulo 15 — Supervisão humana para ações sensíveis à segurança

A aprovação humana deve ser exigida quando ações automatizadas puderem criar impacto material de segurança ou negócio e o sistema não puder limitar o risco de forma confiável por meio de controles determinísticos.

Revisores precisam de contexto, tempo, competência e autoridade suficientes para rejeitar ou interromper a ação. Uma etapa nominal de aprovação sem informação significativa não constitui supervisão eficaz.

Capítulo 16 — Pacote de segurança pré-implantação

Antes da liberação, reúna o modelo de ameaças atual, arquitetura, inventário de ativos, resultados de validação, achados em aberto, evidências de fornecedores, revisão de identidade/permissoes, limites de monitoramento, plano de incidentes, plano de rollback/parada, exceções e aprovações.

O pacote deve corresponder ao candidato exato de liberação, e mudanças materiais devem reabrir as evidências afetadas.

Capítulo 17 — Hardening de implantação

A implantação deve usar configurações aprovadas, identidades de privilégio mínimo, segredos protegidos, caminhos de rede controlados, logging, monitoramento e capacidade de rollback proporcionais ao risco.

O sistema implantado deve ser comparado com o candidato de liberação validado para evitar que drift relevante para segurança seja introduzido durante a promoção.

Capítulo 18 — Monitoramento e alertas

O monitoramento deve se concentrar em indicadores ligados a riscos conhecidos: acesso incomum, mudanças de permissões, falhas repetidas de controles, atividade inesperada de ferramentas, tratamento de dados sensíveis, mudanças de dependências, degradação de disponibilidade e exceções de política.

Alertas devem ter responsáveis, regras de severidade, caminhos de escalonamento e expectativas documentadas de resposta.

Capítulo 19 — Logging e preservação de evidências

Logs relevantes para segurança devem preservar contexto suficiente para apoiar investigações, respeitando privacidade e minimização de dados. Registros úteis podem incluir identidades, timestamps, referências de modelo/configuração, invocações de ferramentas, decisões de política, referências de recuperação e eventos de mudança.

A retenção deve ser definida e o acesso aos logs controlado.

Capítulo 20 — Resposta a incidentes

Eventos de segurança relacionados à IA devem integrar-se ao processo de incidentes da organização. Os planos de resposta devem identificar opções de contenção, evidências a preservar, contatos de fornecedores, caminhos de notificação, etapas de recuperação e critérios para suspender ou restringir o serviço.

Capítulo 21 — Mecanismos de rollback e parada

Sistemas com impacto operacional ou de segurança material devem possuir mecanismos de rollback ou parada testados. A autoridade para acioná-los deve ser explícita.

Um controle que exista apenas no papel não deve receber crédito até ser validado técnica e operacionalmente.

Capítulo 22 — Gestão de mudanças e configuração

Mudanças em modelos, recuperação, prompts, instruções do sistema, ferramentas, permissões, fontes de dados, hospedagem, guardrails ou fornecedores podem alterar a postura de segurança. Os registros de mudança devem classificar materialidade e identificar qual validação anterior permanece válida.

Capítulo 23 — Governança de exceções

Exceções de segurança devem registrar o requisito não atendido, justificativa de negócio, controles compensatórios, responsável, risco residual, aprovador, data de expiração e requisito de monitoramento.

Exceções de alto risco não devem tornar-se permanentes por extensões administrativas repetidas sem reavaliação.

Capítulo 24 — Reavaliação periódica de segurança

A reavaliação periódica deve examinar se ameaças, dependências, acessos, uso de dados, estado de fornecedores, comportamento operacional e premissas anteriores continuam válidos.

A evidência deve mostrar o que foi revisado, o que mudou, o que continua aceitável e qual ação adicional é necessária.

Capítulo 25 — Mudança de fornecedores e dependências

Mudanças de fornecedor ou dependência devem ser avaliadas quanto ao efeito em segurança antes da adoção.

Mudanças relevantes incluem hospedagem, versão do modelo, arquitetura de serviço, processamento de dados, subprocessadores, métodos de acesso, logging, controles de segurança e compromissos contratuais de notificação.

Capítulo 26 — Resiliência e operação degradada

O planejamento de segurança deve considerar como o sistema se comporta quando modelos, APIs, recuperação, monitoramento ou serviços externos estão degradados ou indisponíveis. Modos alternativos não devem contornar silenciosamente controles de segurança, aprovação ou proteção de dados.

Capítulo 27 — Considerações de backup e recuperação

O planejamento de recuperação deve identificar quais configurações, prompts, políticas, índices, credenciais, evidências e dependências são necessários para restaurar um estado controlado conhecido. Procedimentos de recuperação devem ser validados proporcionalmente à criticidade.

Capítulo 28 — Desativação e decomissionamento

A desativação deve revogar identidades, credenciais e integrações; desabilitar endpoints; remover ou arquivar dados conforme requisitos; preservar evidências obrigatórias; encerrar acesso de fornecedores; e documentar obrigações não resolvidas.

Capítulo 29 — Métricas de segurança e reporte gerencial

Métricas devem estar vinculadas a decisões. Relatórios úteis podem incluir achados materiais, exceções, estado de reavaliação, tendências de incidentes, mudanças de dependências, cobertura de validação, remediação vencida e indicadores de saúde de controles.

Capítulo 30 — Limitações da asseguuração de segurança

Nenhuma suíte automatizada de testes, checklist de controles, revisão de segurança ou workflow de repositório pode estabelecer que um sistema de IA esteja livre de fraquezas. Declarações de asseguuração devem identificar escopo, período, evidências e limitações que as sustentam.

Capítulo 31 — Melhoria contínua

Lições de incidentes, quase incidentes, testes, mudanças de fornecedores, feedback de usuários e falhas de controles devem retroalimentar modelos de ameaças, planos de validação, controles operacionais e treinamento.

Capítulo 32 — Limite de liberação do manual

Antes da publicação deste manual devem ser concluídas a verificação de fontes, o mestre controlado completo em inglês, revisão técnica/de segurança, revisão semântica de es-419 e pt-BR, revisão de gráficos/acessibilidade, QA documental e por página, proveniência, auditoria de segurança do repositório e Aprovação Humana Final de Liberação.

Mudanças materiais de conteúdo após aprovação humana reabrem os gates afetados.